

Purple Team Exercise Report

ClickFix → Matanbuchus 3.0 → AstarionRAT — Detection Validation

Exercise date	2026-08-04	Lab	ConDef (DC, Win11v + Sysmon, Splunk)
Source intel	Huntress (Feb 2026)	Detection engine	Hayabusa 3.10.0 + Sigma
Scope	Discovery & Persistence	Classification	Internal / TLP:AMBER

Sanitized copy — credentials, passphrases, cryptographic keys, file hashes, and account SIDs have been redacted. Network IOCs are defanged.

Executive Summary

This exercise replayed the hands-on-keyboard phase of a February 2026 intrusion in which a ClickFix social-engineering lure delivered the Matanbuchus 3.0 loader and a previously undocumented implant (AstarionRAT), followed by rapid domain reconnaissance and rogue administrator creation. Two priority techniques were simulated in the ConDef lab and validated against detection tooling: **Domain Group Discovery (T1069.002)** and **Create Local Admin (T1136.001 / T1098)**.

Outcome: All simulated behaviors were detected. 21 rule hits fired across 10 events (6 high, 6 medium, 9 low). One partial-coverage gap was identified: a localized (Spanish) group-name add generates no account-management audit event and is only visible on the process command line — a correlation rule is recommended to close it.

Attack Chain (context)

Phase	Behavior	ATT&CK;
Initial access	ClickFix paste-and-run → silent MSI install	T1204.004 / T1218.007
Loader	DLL side-loading → Matanbuchus 3.0 → reflective loader	T1574.002 / T1620
Implant	AstarionRAT (encrypted C2 disguised as telemetry)	T1071.001 / T1573
Discovery	net group / nltest domain recon	T1069.002 / T1018
Persistence	Rogue local admin; scheduled task; PsExec spread	T1136.001 / T1098 / T1053.005

Simulated in this exercise: the Discovery and Persistence rows. Earlier loader/implant stages were analyzed, not detonated.

Detection Results

Focus technique 1 — Domain Groups (T1069.002)

Rule	Severity	Event
Proc Exec (Sysmon Alert)	HIGH	Sysmon 1 — net.exe
Proc Exec (Sysmon Alert)	HIGH	Sysmon 1 — net1.exe (child)
Suspicious Group/Account Recon via Net.EXE	MEDIUM	Sysmon 1 (x2)
Net.EXE Execution	LOW	Sysmon 1 (x2)

Both the net.exe invocation and its net1.exe child were caught — rules keyed only on net.exe would miss half the activity.

Focus technique 2 — Create Local Admin (T1136.001 / T1098)

Rule	Severity	Event
User Added To Local Admin Grp	HIGH	Security 4732
Proc Exec (Sysmon Alert)	HIGH	Sysmon 1 — net user / localgroup
Password Reset By Admin	MEDIUM	Security 4724
New User Created Via Net.EXE	MEDIUM	Sysmon 1
User Added to Local Administrators Group	MEDIUM	Sysmon 1
Local User Account Created	LOW	Security 4720
Net.EXE Execution	LOW	Sysmon 1 (x3)

Bundled discovery — Remote System Discovery (T1018)

Rule	Severity	Event
Potential Recon Activity Via Nltest.EXE	MEDIUM	Sysmon 1
Nltest.EXE Execution	LOW	Sysmon 1
Renamed Exe File	LOW	Sysmon 1

Severity Roll-up

Severity	Count	Notable
High	6	4732 admin-group add; Sysmon proc-exec on recon & account creation
Medium	6	net recon, new-user-via-net, password reset, nltest recon
Low	9	generic Net.EXE / account-created / renamed-exe
Total	21	across 10 events, all 2026-08-04

Gap Analysis

Technique	Tested	Hayabusa	Splunk	Verdict
T1069.002 Domain Groups	Yes	Detected	Query ready	Covered
T1136.001 Create Local Account	Yes	Detected	Query ready	Covered
T1098 Add to Administrators	Yes	Detected (4732)	Query ready	Covered
T1098 Add to 'Administradores'	Yes	Process-only	Process-only	Partial
T1018 Remote System Discovery	Yes	Detected	Query ready	Covered

Identified gaps

- **Localized group-name blind spot:** adding an account to a non-existent localized group (e.g. the Spanish 'Administradores' the operator tried first) produces no 4732 audit event. Detection must rely on the process command line, not the group-membership audit or the well-known Administrators SID.
- **SIEM validation outstanding:** Splunk SPL was authored for each technique but not yet executed against ConDef; SIEM coverage is projected, not confirmed.
- **Telemetry provenance:** events were generated as synthetic EVT_X for this exercise. A live detonation would additionally validate EDR-native fields and real file hashes.

Recommendations

- Build a correlation search joining Security 4732 with Sysmon 'net localgroup */add' so localized or failed group-name adds are still caught on command line.
- Alert on net / net1 with 'group /domain' originating from a non-administrative or service logon session.
- Flag process execution from staging directories that imitate legitimate Windows paths (e.g. a ProgramData sub-path mimicking Windows Update).
- Execute the authored Splunk queries to convert projected SIEM coverage to confirmed.
- Train users against paste-and-run (ClickFix) prompts and disable the Run dialog via GPO.

Appendix A — Network IOCs (defanged)

Indicator	Type	Note
bincloudapp[.]com	Domain	Payload delivery; registered 2026-02-05
sectigoapps[.]com	Domain	Same host, brand impersonation
solidcloudapps[.]com	Domain	Same host, brand impersonation
192.121.23[.]146	IPv4	Hosting AS9009 (Germany)
www.ndibstersoft[.]com	Domain	AstarionRAT C2

Redacted from this report: rogue-account credentials, archive passphrase, file hashes, cryptographic keys, and account SIDs. Retained internally in the exercise working files. Generated by the ConDef purple-team workflow.